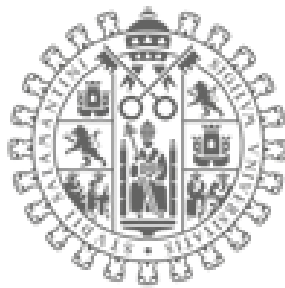


Calidad y Auditoría

Auditoría Informática, Control Interno, Gobierno Corporativo



**VNiVERSiDAD
D SALAMANCA**

CAMPUS OF INTERNATIONAL EXCELLENCE

Miguel Barranquero Diez

Índice

1. Introducción y Definiciones	3
2. Relación entre Auditoría Informática, Control Interno y Gobierno de SI/TI	4
3. Caso Tesco Bank (2016): Ciberataque, Control Interno y Gobernanza	5
Bibliografía	7

1. Introducción y Definiciones

La tecnología y los sistemas de información son elementos esenciales para la gestión y la toma de decisiones en las organizaciones modernas. En este contexto, conceptos como la auditoría informática, el control interno y el gobierno de los sistemas de información (SI/TI) se interrelacionan para garantizar la seguridad, eficiencia y alineación estratégica de los recursos tecnológicos con los objetivos corporativos [1], [2].

Auditoría Informática

La auditoría informática evalúa sistemáticamente si los sistemas informáticos protegen activos, mantienen la integridad y confidencialidad de datos, cumplen objetivos y usan recursos eficientemente [3]. Surgió en los años 60 como evolución de la auditoría financiera, consolidándose con la creación de ISACA en 1969 [4]. Es independiente, puntual y evaluativa, a diferencia del control interno continuo [5].

Control Interno

El control interno incluye políticas y procedimientos continuos para gestionar riesgos, asegurar eficiencia operativa, confiabilidad de la información y cumplimiento normativo [6]. Se clasifica en:

Tipo	Descripción	Ejemplo
Preventivos	Evitan errores o incidentes.	Controles de acceso.
Detectivos	Identifican fallos.	Pruebas de penetración.
Correctivos	Resuelven desviaciones.	Análisis de causa raíz.

Es operativo y permanente, base para auditoría y gobierno [7].

Gobierno Corporativo

El gobierno corporativo es el conjunto de principios, estructuras y procesos mediante los cuales una organización es dirigida y controlada, con el fin de garantizar la transparencia, la responsabilidad y la creación de valor para los accionistas y demás partes interesadas [8]. Esta entidad se ha vuelto crucial para mitigar riesgos, fomentar la innovación y asegurar la resiliencia organizacional frente a crisis económicas o regulatorias.

Dentro de este contexto, el gobierno de Sistemas de Información (SI/TI) constituye una extensión integral del gobierno corporativo. Según el Information Technology Governance Institute (ITGI), se encarga de liderar y establecer estructuras y procesos que aseguren que las Tecnologías de la Información y las Comunicaciones (TIC) respalden y potencien la estrategia y los objetivos organizacionales [2]. En síntesis, el gobierno de SI actúa en un nivel estratégico, orientando la dirección tecnológica de la empresa, mientras que el control interno gestiona la ejecución operativa y la auditoría informática evalúa de forma independiente la eficacia de ambos sistemas.

2. Relación entre Auditoría Informática, Control Interno y Gobierno de SI/TI

La auditoría informática, el control interno y el gobierno de los Sistemas de Información (SI/TI) forman un sistema interrelacionado que garantiza la correcta gestión, seguridad y alineación estratégica de las Tecnologías de la Información dentro de una organización [9]. El gobierno de SI, como parte del gobierno corporativo, establece la dirección estratégica, define las políticas, los roles y las responsabilidades que guían el uso de las TIC para asegurar que contribuyan al cumplimiento de los objetivos empresariales y a la generación de valor. En este marco, el control interno actúa como el mecanismo operativo que implementa y mantiene esas directrices en el día a día, asegurando la eficacia, la integridad de la información, la continuidad operativa y el cumplimiento normativo [6]. A su vez, la auditoría informática se posiciona como una función independiente y evaluativa, encargada de verificar que tanto el gobierno como los controles internos se apliquen correctamente, sean eficaces y se ajusten a las mejores prácticas [3]. De esta manera, mientras el gobierno de SI define el “qué” y el “por qué”, el control interno ejecuta el “cómo” y la auditoría valida el “qué tan bien”, cerrando un ciclo de mejora continua que refuerza la confianza, la transparencia y la eficiencia en el uso de los recursos tecnológicos de la organización [10].

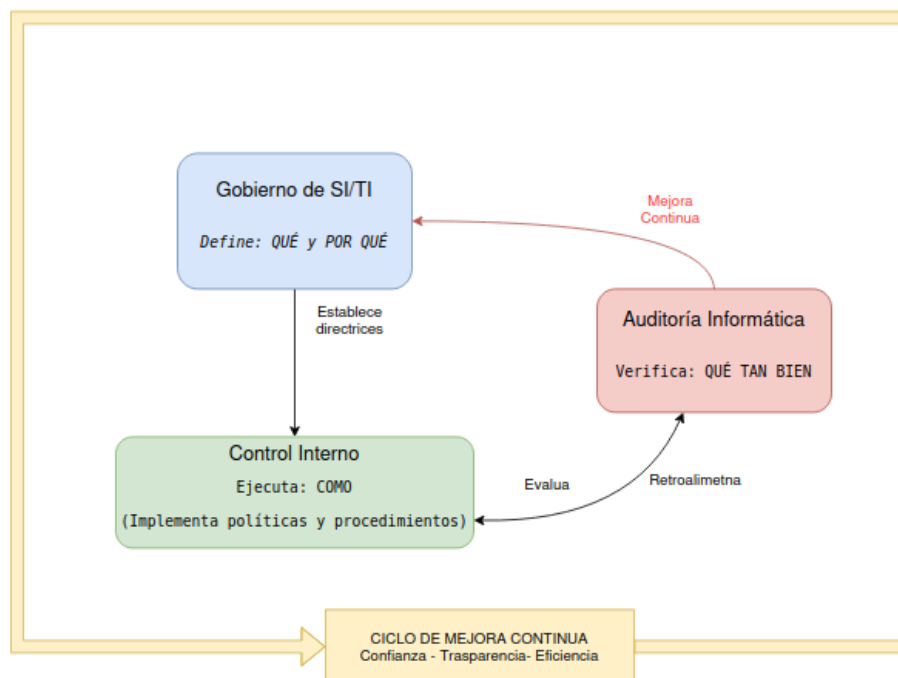


Figure 1: Esquema que ilustra la relación entre Auditoría Informática, Control Interno y Gobierno de SI/TI, mostrando la dependencia y roles específicos de cada concepto.

3. Caso Tesco Bank (2016): Ciberataque, Control Interno y Gobernanza

Tesco Bank, la filial bancaria del gigante minorista Tesco en el Reino Unido, experimentó un ciberataque significativo en noviembre de 2016. Este incidente comprometió más de 9.000 cuentas de clientes y resultó en pérdidas financieras que ascendieron a más de 2,5 millones de libras esterlinas. La gravedad del suceso motivó una exhaustiva investigación por parte de la Autoridad de Conducta Financiera del Reino Unido (FCA), que posteriormente impuso una multa considerable al banco por fallos en sus sistemas de protección.



Figure 2: Noticia - Periódico EL Mundo.

Fallos en la Auditoría Informática

La investigación post-incidente, apoyada por auditorías informáticas internas y externas, reveló deficiencias fundamentales que permitieron la explotación. Entre los hallazgos más relevantes se determinó que los sistemas de detección de fraude no estaban configurados con la sensibilidad adecuada, lo que facilitó el robo. Además, se identificaron debilidades en la segmentación de redes y una supervisión ineficaz de las transacciones catalogadas como sospechosas. La FCA también señaló que el software crítico del banco no había sido sometido a pruebas de seguridad ni revisiones periódicas. Esto subraya que la falta de una auditoría informática rigurosa y continua impedía la detección preventiva de vulnerabilidades.

Debilidad del Control Interno

El informe final de la FCA fue categórico al señalar que Tesco Bank no poseía controles internos robustos para mitigar los riesgos inherentes a la tecnología bancaria. Las deficiencias incluían:

- Falta de revisión: Ausencia de un proceso de revisión y gestión regular de los accesos a los sistemas considerados críticos.
- Documentación de incidentes: Escasa o deficiente documentación de los procedimientos para la respuesta y recuperación ante incidentes de ciberseguridad.
- Coordinación: Una notoria falta de coordinación y comunicación fluida entre el área de Tecnología de la Información (TI) y los departamentos encargados de la gestión de riesgos empresariales.

La lección primordial es que los controles internos deben estar plenamente operativos e integrados en la gestión diaria, no ser meros elementos teóricos.

Deficiencias en el Gobierno Corporativo

El ciberataque evidenció una debilidad estructural a nivel del gobierno corporativo. Se constató que el Consejo de Administración no recibía reportes técnicos sobre ciberseguridad que fueran claros, precisos y escalados adecuadamente para la toma de decisiones ejecutivas. De forma crucial, no existía un comité especializado y dedicado a la supervisión de riesgos tecnológicos. Esta situación sugería que la alta dirección subestimó la criticidad de la seguridad informática, tratándola como una responsabilidad exclusiva del departamento de TI en lugar de un componente estratégico de la gestión corporativa general.

Consecuencias

Las consecuencias del incidente fueron significativas. La FCA impuso una multa de £16,4 millones por no actuar con la debida habilidad, cuidado y diligencia para proteger los fondos de sus clientes. Además de la multa y el resarcimiento de las pérdidas, el banco sufrió un notable daño reputacional.

Como resultado, Tesco Bank se vio forzado a implementar profundas reformas, incluyendo la creación de un Comité de Riesgos Tecnológicos y la instauración de auditorías informáticas de seguridad obligatorias y periódicas. El caso sirve como prueba de cómo la ausencia de controles internos y auditorías informáticas rigurosas puede socavar el gobierno corporativo, generar cuantiosas pérdidas y destruir la confianza pública.

Bibliografía

- [1] ISACA, *COBIT 5: A Business Framework for the Governance and Management of Enterprise IT*. Rolling Meadows, IL: ISACA, 2012.
- [2] Information Technology Governance Institute, *Board Briefing on IT Governance*, 2nd ed. Rolling Meadows, IL: ITGI, 2003.
- [3] ISACA, *IS Auditing Standards and Guidelines*. Rolling Meadows, IL: ISACA, 2011.
- [4] ISACA, "History of ISACA and the IT Audit Profession." [Online]. Available: <https://www.isaca.org/about-us/history>
- [5] Z. Rezaee, *Financial Institutions, IT Auditing, and Internal Control*. New York: Wiley, 2001.
- [6] Committee of Sponsoring Organizations of the Treadway Commission, "Internal Control – Integrated Framework." COSO, 2013.
- [7] O. R. Whittington and K. Pany, *Principles of Auditing and Other Assurance Services*. New York: McGraw-Hill, 2019.
- [8] Organisation for Economic Co-operation and Development, *G20/OECD Principles of Corporate Governance*. Paris: OECD Publishing, 2015. doi: 10.1787/9789264236882-en.
- [9] R. Peterson, "Crafting Information Technology Governance," *Information Systems Management*, vol. 21, no. 4, pp. 7–22, 2004, doi: 10.1201/1078/44705.21.4.20040901/84183.2.
- [10] P. Weill and J. W. Ross, *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results*. Boston: Harvard Business School Press, 2004.